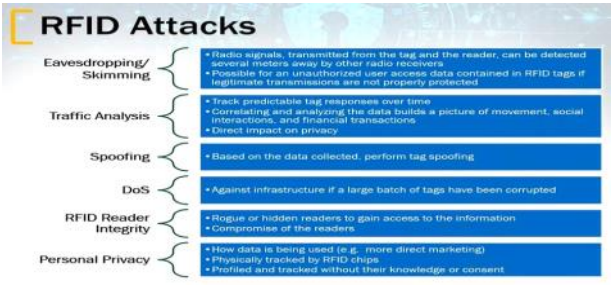
Domain 5: Identity and Access Management (IAM)

- Control physical and logical access to assets
  - Object: - A Passive entity that contains information or functionality i.e. Ex: Server
  - Subject: - A user, program, or process that requests access to an object or the data within an object i.e. ex: user
  - Access: - The flow of information between a subject and an object.
  - Access Control Systems
    - Physical or electronic systems designed to control who, or what has access to a network. The simplest example is a door that can be locked, limiting people to one side of the door or the other.
      - By - Whom (Employees, 3rd Party, Guest, Anonymous)
      - What (Device, Identified, Anonymous)
      - To - Assets - Information, Systems, Devices, and Facilities
        There are two types of Access Control systems
- Physical (Physical lock)
  - History of "whom" and "when"
  - Time and Attendance
- Technical/Logical
  - Built into OS
  - Part of logic of APP or DB
  - 3rd Party
  - Regulate communication
- Comparing Permissions, Rights, and Privileges
  - **Permissions** In general, permissions refer to the access granted for an object and determine what you can do with it. If you have read permission for a file, you'll be able to open it and read it.
  - **Rights** A right primarily refers to the ability to take an action on an object. For example, a user might have the right to modify the system time on a computer or the right to restore backed-up data
  - **Privileges** are a combination of rights and permissions. For example, an administrator for a computer will have full privileges, granting the administrator full rights and permissions on the computer
- **Implicit Deny**
  - A fundamental principle of access control is implicit deny, and most authorization mechanisms use it. The implicit deny principle ensures that access to an object is denied unless access has been explicitly granted to a subject
    - For example,imagine an administrator explicitly grants Jeff Full Control permissions to a file but does not explicitly grant permissions to anyone else. Mary doesn't have any access even though the administrator didn't explicitly deny her access. Instead, the implicit deny principle denies access to Mary and everyone else except for Jeff. You can also think of this as deny by default.
- **ISO/IEC 27000:2016 = Define access control**
  - Administration of Logical access control
    - Most complex and challenging task
    - Includes
      - Implementing -
      - Monitoring - Checking the Goals, mitigation Risk.
      - Modifying - If we identify any gap we modify the as per change management process.
      - Testing - once modify we test the control.
      - Terminating - if not in required we terminate.
    - All this is done based on the conditions set by the information owner and system owner
- Approach to Administration the access control
  - Centralized administration
    - Centralized administration means that one element is responsible for configuring access controls so that users can access data and perform the activities they need to.
    - The main advantage of centralized administration is that very strict control over information can be maintained because the ability to make changes resides with very few persons. Easy to Manage.
    - Consistent and uniform procedures and criteria.
  - Decentralized administration (user decides)
    - In contrast to centralized administration, decentralized administration means that access to information is controlled by the owners or creators of the files, whoever or wherever those individuals may be.
    - An advantage of decentralized administration is that control is in the hands of the individuals most accountable

for the information, most familiar with it, and best able to judge who should be able to do what in relation to it.
    - One disadvantage, however, is that there may not be consistency among creators/owners as to procedures and criteria for granting user access and capabilities.
    - Another disadvantage is that when requests are not processed centrally, it may be more difficult to form a system-wide view of all user access on the system at any given time.
- Hybrid approach.
    - In a hybrid approach, centralized control is exercised for some information, and decentralized is allowed for other information.
    - One typical arrangement is that central administration is responsible for the broadest and most basic access, and the creators/owners of files control the types of access or users' abilities for the files under their control
- Physical Access Control (PACS)
    - Physical Access Control is about the **accessibility of Space**
    - Granting or restricting access to buildings, rooms, and floors is controlling access to certain spaces.
    - The accessibility of these spaces is usually controlled by a key, Token, or Card.
    - Granular Control - Temporal controls based on time, date, day holiday.
- Implementing access control services involves:
    - Identifying the individual or entity attempting to access an object.
    - Verifying or authenticating the individual's identity.
    - Evaluating the rules and/or roles to see what the individual is permitted to do.
    - Creating an audit trail by writing each access attempt and function performed to a log file.
    - Reviewing the log to see what was completed when and by whom. This review is performed by managers and supervisors and helps to create accountability in the system access process
- Methods
    - Dual control/custody two valid keys have to be present to the reader within a certain time.
    - Key - Key Inventory
    - Badge or Token stored information on is presented to a reader
    - Biometric - Physiological or behavioral characteristics
- Access Control System Considerations
    - Access control policies (How access is managed)
    - Mechanisms (ACL/read access)
    - Models (Centralized/de-centralized)
- Access Control Guidelines
    - Guidelines for Planning Physical and Logical Access. Use the following guidelines when planning physical and logical access controls:
        - Draft access control matrices to get a better view of how access is provisioned for each of your systems.
        - Verify that your operating system's security kernel uses an effective reference monitor to enforce access control between subjects and objects.
        - Choose between centralized, decentralized, or hybrid access control administration depending on your business needs and capabilities.
        - Follow the identity and access provisioning process, remembering to periodically review access and come up with a plan for revoking access.
        - Draft access control policies at an administrative level that can be easily translated into technical policies.
        - Create a logical and physical perimeter around your facility to keep intruders from gaining access.
        - Create points of access within your facilities, like locked doors, to maintain different levels of access within the organization itself.
        - Consider implementing deterrent controls to prevent attackers from even trying to gain access.
        - Make sure that critical utilities like HVAC are using modern authentication and authorization protocols if they're networked.
- Make sure databases storing sensitive information employ access control, as well as any communication channels they use.
- Provide degrees of access to information, such as read access versus write access.
- Consider that information may be stored physically on servers containing databases, or hard copy documents, and that either one may be the target of attack.
- Make sure that remote access to systems is tightly controlled.
- Ensure that networking equipment is stored safely in locked containers to prevent theft and damage.
- Implement directory services to provide access control on user devices.
- Consider the challenges of mobile devices and the BYOD phenomenon with respect to attackers.
- Gaining access to personal devices that contain company information.
- Access Control Attacks

- Privileged Escalation
  - Privileged Escalation attacks are designed to gain elevated access to resources that are normally protected from an application or user (generally by exploiting a vulnerability or weak authentication).
- Advanced Persistent Threat (APT)
  - An Advanced Persistent Threat (APT) is a sophisticated attack in which an intruder establishes a presence on a network to mine private data.

- **Manage identification and authentication of people, devices, and services**
  - Identification, Authentication, and Authorization
    - **Relationship between Identification, Authentication, and Authorization**
      - **Identification provides uniqueness**
      - **Authentication provides validity of the identity**
      - **Authorization provides control over access levels**
        - Authorization is a two-part concept. When an identity is created during provisioning it must be granted access or permissions, which is an authorization action Each time the subject makes requests for access, the system should again confirm authorization to ensure the subject is still authorized to access the given object.Additionally, systems should enforce accountability for system actions taken by a subject, which is often done by logging the actions for review.
    - **Identification**
      - Assertion of a unique identity for a person or system and is the starting point of all the access control
      - Without proper identification, it is impossible to determine how to apply the appropriate controls
    - **Authentication**
      - Process of verifying the identity of the user
      - User provides some set of private data that only he or she has access to or knowledge.
      - Something you know, something you are, and something you have. Without authentication, auditing (Accountability) will not be effective.
    - principle of least privilege by preventing privilege creep.
  - **Authorization**
    - Process of defining the specific resources a user needs
    - And determining the type of access to those resources the user may have.
- **Identification Methods**
  - Access Badge
    - Access Badge is more important than identification badge, access badge is not physically tied to a person.
  - User ID
    - User ID is an identifier, not an authenticator
  - Account Number, MAC Address, IP Address, Identification Badge
- **RFID (Radio Frequency identification) is read by an RFID reader automatically.**
  - A non-contact automatic identification technology that uses radio signals from an RFID tag.
    - Can identify and track resources without the need for direct contact or line of sight.
    - E.g. People, Vehicles, goods, and assets.
  - **Fastest ways to identify assets in case of a disaster is RFID**
  - Biggest concern in RFID privacy breach
  - RFID tag components
    - Integration circuit for modulating / demodulating radio signal
    - Antenna for receiving and transmitting the signal
    - Chipless RFID tags do not have any integrated circuit
  - RFID Attack



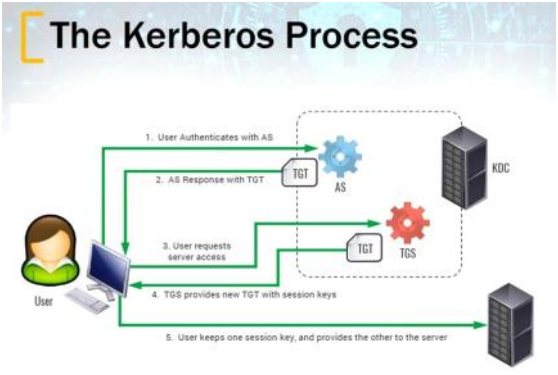
- Identity and Access Service
  - Identity and access services is a term used to describe authentication, authorization, and accounting functions.

An authentication protocol is used solely for user validation (authentication).

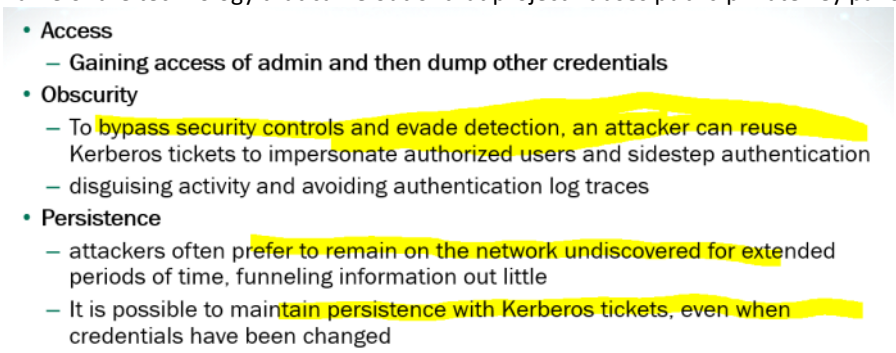
- AAA architecture protocols are used for validating the user (authentication), controlling access to server data (authorization), and monitoring network resources use (accounting).
- **Identity Management Implementation**
  - Technologies utilized in identity management solutions include:
    - A Typical directory contains a hierarchy of objects storing information about:
      - Users - Groups - Systems - Servers - Printers



- Single Sign-ON
  - Single sign-on (SSO) provides the capability to authenticate once and be subsequently and automatically authenticated when accessing various resources.
  - Unified login experience, from the viewpoint of the end-user, when accessing one or more systems.
  - Central repository of user credentials (e.g user IDs and passwords, associated with a suite of applications)
  - User launches applications via SSO client, which opens the appropriate application program and sends the appropriate login keystrokes.
  - SSO client simulates a user typing his own user ID and password
  - Single Point of Failure biggest Concern
  - Weakness of Centralized SSO Systems
    - All of a user's credentials are protected by a single password
    - Many SSO systems store all the user credentials and authentication information in a single database.
- **Kerberos**
  - Uses Symmetric Encryption (AES)
  - **The primary goal of Kerberos is to ensure private communications between systems over a network.**
  - SSO authentication system that provides enhanced security features.
  - Greek word, The Kerberos security system guards a network with three elements
    - Authentication
    - Authorization
    - Auditing
  - Based on the interaction between three systems
    - Requesting system
    - Endpoint destination server
    - Kerberos or Key Distribution Center (KDC) who issues the ticket



  - Kerberos Tickets
    - The User is authenticated once via a traditional log-on process and verified by message encryption to request and acquire service tickets.
    - When the user authenticated to AS (Authenticate Server), it simple receives a TGT (Ticket Granting Ticket)
    - The TGT allows the user to request a service ticket from the TGS (Ticket Granting Service), Authenticating through encryption processes, and building an ST (Service Ticket) for a user to present to the target resource

system
    - The Possession of ST signifies the user has been authenticated and access can be provided.
    - Ticket have lifeline
- Drawbacks of Kerberos:
    - The security of the whole system depends on careful implementation.
    - KDC can be a target
    - KDC can be a single point of failure and should be supported by backup and continuity plans
    - The length and lifetime of the keys is very important.
- An alternate is Kerberos is SESAME and Krypto knight.
    - SESAME (a Secure European System for Applications in a Multi-vendor Environment) is a European research and development project, part-funded by the European Commission under its RACE programmed. It is also the name of the technology that came out of that project. It uses public-private key pairs.
    - 

- Authentication Factor Requirement
    - Something you know. e.g. Password or Pin
    - Something you have. e.g. Token
    - Something you are. e.g. Biometrics
    - Somewhere you are e.g. Location-based Authentication.
    - Single/Multi-Factor Authentication
        - Single-factor Only one factor is required for authentication
            - Weaker
        - **Multi-layer Two or more of the same type of factor is required for authentication**
            - More Secure, Increases trust level of authenticity.
    - Multi-Factor
        - **Something You Have**
        - Token - One Time Password
            - Used to prove their identity and authenticate a claimant to a system or application
            - Input data may be a Nonce or a challenge number or may be supplied by a token.
            - Hold a symmetric or asymmetric secret.
            - May require a user PIN.
        - Soft Token
            - Soft Token implementation
                - Stored on a general-purpose computer
                - Require activation through a second factor.
                - Private keys must be non-exportable.
                - Never store keys in plaintext or unencrypted form.
                - Biggest concern: Human Error.
            - Compared to hard tokens:
                - Generally cheaper to implement
                - Easier to manage than hard tokens
                - Avoid some physical security risks
        - **Soft token Guidelines.**
            - Private keys must be non-exportable
            - Never store keys in plaintext or Undecrypted form
            - Distributing the seed record and initial passphrases requires a confidential channel
            - Activation of the token must occur every time user authenticates
            - Token time limit must be 2 minutes or less

        - Password/PIN should follow password management guidelines
        - Audit all access to software tokens
        - Always install latest version of malware prevention software before software tokens
        - Always use **FIPS-140-2 v**alidated cryptographic modules.
    - Password Attacks
        - **Spraying attack** is a special type of brute-force attack.
            - Attackers use spraying attacks in online password attacks, attempting to bypass account lockout security controls.Usually, a system will lock out an account if the same user enters the wrong password too many times within a short amount of time, such as 30 minutes. In a spraying attack, a program uses the same guessed password but loops through a list of different accounts and different systems.When it finishes the list, it picks another password and loops through the list again. The list is long, and it typically takes the program as long as 15 to 30 minutes to loop through it
        - **Credential stuffing** is sometimes confused with password spraying, but the two attacks are different. Password spraying attempts to bypass account lockout policies, whereas credential stuffing only checks a single username and password on each site
        - **Pass-the- Hash Attack**
          attack allows an attacker to send a captured hash of a password to an authenticating service. Normally, the user would enter a password on the client, and the client would then create the password hash and send the hash. In this attack, the attacker doesn't need to know the actual password.
        - ARP spoofing is also a common precursor to man-in- the- middle(MITM) attacks and session hijacking attacks.
        - There are two main ways to prevent or detect MITM attacks: authentication and tamper detection
        - Authentication provides some degree of certainty that a given message has come from a legitimate source. Tamper detection merely shows evidence that a message may have been altered.

- Additional security controls
    - PKI is the preferred key management platform
    - Use available Trusted Platform Modules (TPM)
    - Perform self-validation before issuing a token
- **Hard Token**
    - Hard Token Implementation
        - Non-software physical tokens that store credentials on hardened dedicated devices used to authenticate an identity
        - Susceptible to physical security attacks, such as direct physical access, if lost or stolen.
    - Type of Hard Token (IMP EXAM)
        - Look up secret Token
            - Stores a set of secrets
            - Is used to look-up the secret based on a prompt from the authentication protocol.
            - Credit/Debit card Grid secret
        - Out of Band token - Sends over the network
            - User receives a password over a separate channel from the primary authentication channel
            - User provides that password to the authentication protocol using the primary channel. e.g. SMS Message to a cell phone.
        - Synchronous OTP
            - Device displays a password and the user manually enter e.g. time-based
            - Token may be activated by entry of user activation data
            - RSA is the best example, generates 6 digit value, Internal mathematical calculation,
        - Asynchronous OTP
            - Authentication requires entry of the user activation data such as Password or PIN
            - Cryptographic Device - holds private key to encrypt the response
            - Challenge-response - performs a hash
- Biometric System Process
    - **Something you are**
    - Observation or collection of the biometric data
    - Converts and describes:
        - The observed data using a digital representation called a template
    - Compares
        - The newly acquired template with one or more previously generated templates
    - Biometric system checks for 95% accuracy.
    - Biometric system accurate authentication and least acceptable.

- Biometric system - fingerprint, retina scan.
- Biometric devices rely on measurements of the biological characteristics of an individual.
- Gaining user acceptance is the most common difficulty with the biometric system
- Selected individual characteristics are stored and compared with the presented template
- **Effectiveness Parameters for Biometrics**
  - Enrollment time
    - The enrollment time for a biometric system should be kept at a minimum. A low enrollment time leads to higher user acceptance
  - Throughput
    - Throughput or processing time implies the time taken by a biometric system to process an authentication request initiated by a user to approve or deny access. High throughput is a factor considered during the deployment of a biometric system.
  - User Acceptance
    - A biometric system should have a high level of user acceptance. Users must be informed that the organizational resources should be protected and that the system is not intrusive.
- **Types of Failure in Biometric Identification (EXAM IMP)**
  - False Reject Rate (FRR) (Type 1)
    - Authorized user to whom the system incorrectly denies access. Stated as a Percentage
    - **Reducing the system sensitivity reduces the FRR but increases the FAR**
  - False Accept Rate (FAR) (Type 2)
    - Unauthorized user to whom the system incorrectly grants access. Stated as a Percentage
    - **Increasing the system sensitivity reduces the FAR but increases the FRR**
  - Crossover Error Rate (CER)
    - The point at which FAR equals FRR is stated as a percentage.
    - **The lower the CER the more accurate is the system**
    - **When FRR equals FAR is called a CER.**
    - Also known as the **Equal Error Rate (EER)**
- Biometric Readers
  - Physiological / Physical attributes
    - Unique attributes based on the shape or physical features of the body
    - Includes things like fingerprints, palm prints, and facial features
    - Iris scans are the best biometric system
  - Fingerprints
    - The idea depends on matching the finger patterns of suspicious persons against the one(s) extracted from the crime scene. A fingerprint is one of the unique features that can never be shared between two humans.
    - There are two approaches for capturing the **fingerprint** image for matching
    - minutia matching
      - Minutia matching is a more microscopic approach that analyzes the features of the fingerprint
    - global pattern matching
      - The more macroscopic approach is global pattern matching where the flow of the ridges is compared at all locations between a pair of fingerprint images; however, this can be affected by the direction that the image is rotated.
  - Hand Geometry
    - Besides fingerprints, the shape and dimensions of the hand can also be used as a method to identify a person. The use of this method is not widespread like fingerprints.
    - Speed of hand recognition tent to be more rapid than a fingerprint.
    - Durable Easily understood
    - More accurate, as the shape of the hand is unique.
    - Dis-advantage Provides higher FAR than Fingerprint.
  - Retina Scan
    - The eye-print or retina scan is the most accurate biometric identification and authentication method. This method depends on taking a picture of the eye with details of the blood vessels located in the back of the eye.
    - Retina Scan is a more accurate form of Authentication.
    - Reviles the user privacy, health information.
    - Retina Scan is accurate but not accepted.
    - **Retinal & Vascular Patterns - Requires a person to be alive but least acceptable**
  - Iris Scan

- Another accurate method using the eye is the iris scan. In this method, the patterns of the iris are scanned and checked against a database of stored iris patterns.
- Behavioral attributes
  - Unique attributes based on a subjects speech or movement patterns
  - Includes signature dynamics, keystroke dynamics, or speech patterns
- **Keystroke dynamics** look at the way a person types at a keyboard. Specifically, keyboard dynamics measures two distinct variables
  - "dwell time" is the amount of time you hold down a particular key
  - "flight time" is the amount of time it takes a person to switch between keys.
  - Keyboard dynamics systems can measure one's keyboard input up to 1000 times per second.
- Voice Recognition
  - In this method, the enrollment is done first by asking the user to say a specific phrase to be recorded. On authentication, the person is asked to say the same phrase again to be compared with the original. Even though some voices appear to be very similar, they are still unique, so special devices can differentiate between voices.
- Signature Dynamics
  - This combination is unique in a way that makes signature dynamics an effective identification and authentication method. The writing process produces electrical signals that can be stored in a database. On authentication, the user is asked to sign his signature. The resulting signals are compared to the previously-enrolled ones.

- **Two Most Accurate biometric system - Isis Scans & Vascular Pattern Scans**
- The order of effectiveness has not changed for a few years. It is still the same today as it was three years ago.

  The list below presents them from most effective to least effective:

  1. Iris scan
  2. Retina scan
  3. Fingerprint
  4. Hand geometry
  5. Voice pattern
  6. Keystroke pattern
  7. Signature
- The order of Acceptance, Here is the list from most accepted first to least accepted at the bottom of the list:

  1. Voice Pattern
  2. Keystroke pattern
  3. Signature
  4. Hand geometry
  5. Handprint
  6. Fingerprint
  7. Iris
  8. Retina pattern

- When considering FAR, FRR, and CER, smaller values are better.
- FAR errors are more dangerous than FRR errors.
- Security professionals can use the CER for comparative analysis when helping their organization decide which system to implement.
- For example, voice print systems usually have higher CERs than iris scans, hand geometry, or fingerprints.

- **Accountability**
  - Accountability is being able to determine whom or what is responsible for an action and can be held responsible.
  - One of the driving factors of strong identification, authentication, auditing, and session management is accountability
  - To establishes strong Accountability we need strong Authentication.
  - Accountability ensures that account management has assurance that only authorized users are accessing the system and that they are using the system properly
  - Ultimately one of the drivers behind strong identification, authentication, auditing, and session management is accountability
- **Identify Proofing**
  - Process of collecting the verifying information before issuing the ID. Collect and Verify information about a user to prove that a user is indeed who he or she claims to be, Establishes a reliable relationship - that's trusted electronically between the user and credential for electronic authentication.

- Registration and Proofing of Identity
  - NIST SP 800-63-3 contains three levels of assurance for digital identities
    - IAL1: Self-Asserted
    - IAL2: Remote or In-Person
    - IAL3: Verified by Authorized credential service provider
      - Authenticator Assurance Level
      - Federation Assurance Level

- **Implement and manage authorization mechanisms**
  - Centralized -- Manage by Admin
  - Decentralized -- Manager by User
  - Non-Discretionary Access Control (Non-DAC) - Administrator controls everything
    - Based on the assignment of permissions to read, write, and execute files on a system.
    - Requires the administrator to define and tightly control the access rules for files in the system.
    - Run with Admin in Windows example on NDAC
  - Discretionary Access Control (DAC) - Control By the user
    - DAC allows object owners to control access directly to their objects
    - DAC is implemented using Access Control Lists (ACL) and configured within an Operating System.
    - Owner determine who can access, Provides Fixability
    - **NDAC can overwrite DAC (Administrator can over-write the user)**
      Major disadvantages of discretionary access control techniques such as ACLs or role-based access control include
    - Lack of centralized administration
    - Dependence on security-conscious resource owners
    - Many popular operating systems defaulting to full access for everyone if
    - the owner doesn't explicitly set permissions
    - Difficult, if not impossible, auditing because of the large volume of log entries that can be generated

- **Role-Based Access controls (RBAC)**
  - Job function, Role Keywords
  - It's a DAC Model
    - The determination of what roles have access to a file can be governed by the owner of the data, as with DACs, or applied based on policy.
    - RBAC is a form of DAC because the roles are determined by managers or HR and the access is determined by owners in accordance with company policy.
    - These are all discretionary actions.
    - Bases access control authorization on roles or functions, assigned to a user
    - Determination of what roles have to access a resource can be governed by the owner of the data or applied based on policy.
    - User assigned to a specific role (function), based on the function the user performs roles.
    - Roles defined ex: Network Admin, Systems Admin, Backup Admin
    - RBAC Architectures
      - Non-RBAC
        - Users are mapped to applications
      - Limited RBAC Management
        - Users are mapped to application roles
        - Users are also mapped to an application that has not developed RBAC
        - E.g. Role A - Application 1
          Role B - Application 2 Application 3
      - Hybrid RBAC Management
        - Users are mapped to multi-application roles.
        - Only select application access rights are moved to the multi-application role.
          - E.g. Role A - Application 1 and 2
            Role B for Application 3
      - Full RBAC Management
        - Users are mapped to enterprise roles
          For e.g. Role A - Application 1,2,3
    - **RBAC is vulnerable for Authorization creep (scope creep)** - old access is not removed due to lack of monitoring

of access audit. The user shouldn't get more privileges than what's is required.
    - Compared to other access control paradigms, **RBAC can reduce employee downtime and simplify account provisioning.**
- **Rule-Based Access controls**
    - It's a DAC Model
    - Access is based on a list of predefined rules that determine what access should be granted.
    - The rules, created or authorized by system owners, specify the privileges granted to users when a specific condition of a rule is met
    - E.g. - Firewall rules, User 9 am to 5 pm allow access, or reject.
    - Access based on situational **if-then statements Rules**
- **Content Dependent -** Filter based on the data being acted upon Keywords, Categories
- **Context-Dependent -** Access based on a collection or sequence of actions Rules, Security Policy
- **Constrained Interface -** Access restricted by functionality Design, Configuration
    - Menus and shells
    - Database views
- **Time-Based Access Control** Limits when an individual can access the system
- **Mandatory Access controls (MAC) EXAM IMP**
    - MAC Enforcement is always NDAC in Nature. **Clearance level, need to know Keywords**
    - It is based on cooperative interaction between the system and the information owner. The system's decision controls access, and the owner provides the need-to-know control. Not everyone who is cleared should have access, only those cleared and with a need to know.
    - Require the system to manage access controls in accordance with the organization's hierarchical security policies
    - Typically used for system and data that are highly sensitive
        - Subject assigned, Clearance levels
        - Object assigned sensitivity labels
        - Access requests must pass two tests to provide access:
            - Is Request permitted by security policy?
            - Is Request permitted by the information owner?
    - It is always driven by Administrator & system-level policy
    - Mainly used in Army, the primary objective is Confidentiality - Orange book
    - **Mandatory = you can't change it (or) customize it.**
    - Major disadvantages of mandatory access control techniques include
        - □ Lack of flexibility
        - □ Difficulty in implementing and programming
        - □ User frustration

- **Access Control Matrix**
    - User Table & Capability Table for everyone object we define this
    - An access control matrix is made of a table of subject & objects and the actions that can occur between them
    - They are used to tell the system what table lookups need to be enforced.
    - **Access control matrices are most common for DAC models as rights can be applied to subjects** (capabilities) or Object (ACLs)
    - Capability Table
        - Capability tables determine access rights between a subject and a certain object.
        - A subject is bound to a capability table and the object to an ACL
        - Capabilities can be contained in a key, a ticket, or a token.
- **Attribute-Based Access controls (ABAC) (EXAM IMP)**
    - Its extension of rule-based access control.
    - Attribute-based access control (ABAC) is a logical access control model that controls access to objects by evaluating rules against the attributes of entities (both subject and object), operations, and the environment relevant to a request.
    - ABAC provides more flexibility than other access control models and can be used to achieve more dynamic and risk-based access control.
    - ABAC is similar to RBAC models, but defines a complex policy to allow or deny access rather than a binary allow/deny decision
    - ABAC systems are capable of enforcing both DAC & MAC models.
    - ABAC system can even be made to adapt to risk change, by expressing the risk values as variable attributes.
    - Policies with which ABAC Operate are written in a structured language called XACML
    - Mandatory to review my video **SAML Video**

- Many software-defined networks (SDNs) use the ABAC model. Additionally, ABAC allows administrators to create rules within a policy using plain language statements such as “Allow Managers to access the WAN using a mobile device.”

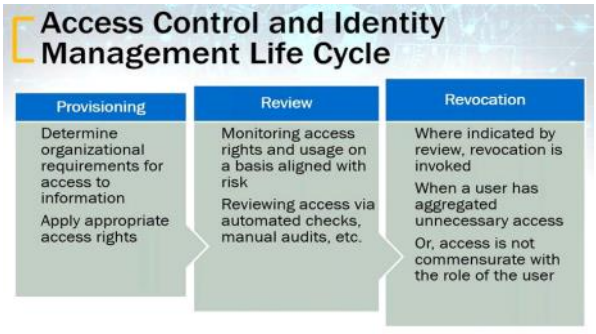
For questions, clarity refer **Access Control Coffee Dose V.1** Link

Exam Summary

Questions	Answer
Owner | user centeric | ACL	DAC
lot of **flexibility** to the user and **less administration** for IT	DAC
Government | Clearance |label | NDAC Strict access control | Need-to-know	MAC
• user job roles • best system for a company that has high employee turnover	RBAC
Firewall	Rule Based
Attribute | Dynamic	ABAC
Account lockout	Context based
Data content	Content Based

1. DAC = Discretionary = Control by User
2. NDAC = Non-Discretionary = By Admin
3. MAC = is NDAC
4. RULE BASED = DAC

- **Manage the identity and access provisioning lifecycle**
  - Identity and Access Management (IAM)
    - Obtain visibility and control over user access privileges, who has access to what.
    - Detective controls
    - Corrective controls (Periodic Recertification)
    - Access policy with implementing rules.
    - Automated account reconciliation to detect unauthorized changes
  - Life Cycle
    - User Access Review
      - Enforce security policy
      - Continues over the lifecycle of access
      - Mitigates vulnerabilities associated with aggregation
      - Conclude with the termination of access
    - System Account Access Review
      - Presents often-exploited vulnerability for attackers
      - Securing begins with renaming the account.
      - Some system account further complicated by being service accounts
    - Provisioning & DE Provisioning
      - Provision a user account and apply for user permission
      - Modify user permission
      - DE provision user account and end-user permission



- **Integrate identity as a third-party service**
  - Federated Identity
    - Federated Identity Systems allow trust access and verification across multiple organizations.
    - **A Federated identity is a portable identity, and its associated entitlements, that can be used across business entitlements, It allows a user to be authenticated across multiple IT systems and enterprises.**
    - , OAuth, Open-ID

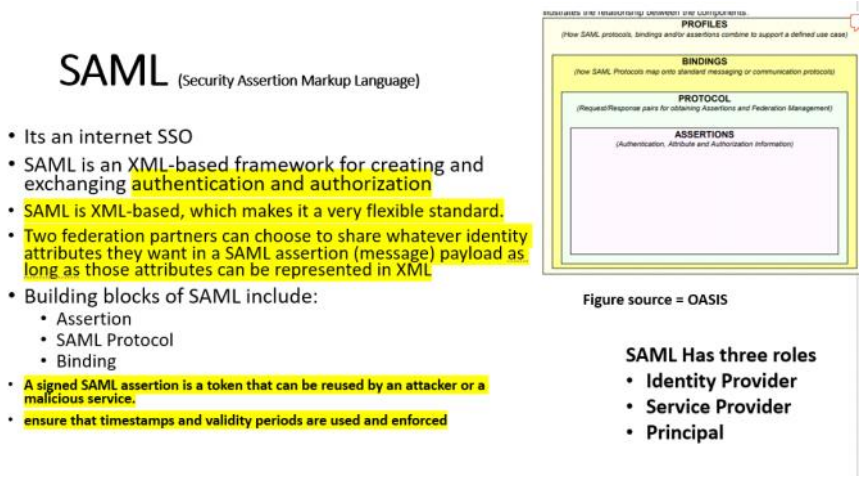
- User wants to access cross multiple domains -- Keywords
- Federated Identity Management
  - Each organization in the federation subscribes to a common:
    - Set of policies, standards, and procedures for provisioning and managing user identification, authentication, and authorization information.
    - Process for access control of systems these users must access.
    - Federated identities link user profile information at multiple locations without synchronization or directory consolidation.
  - **SSO with Multiple Domains - without synchronization of identities**
  - Three Primary Types of Federated Identities
    - Cross Certification
    - Trusted Third-Party Model
    - Security Assertion Markup Language (SAML)
  - **In Cross Certification and Trusted Third-Party model we rely on the API to integrate the multi-domains**
  - Cross Certification
    - Each Organization must individually certify that every other participating organization is worthy of its trust
    - Organizations review each other's processes standards and their due diligence.
    - **Drawback is Scalability.**
  - Trusted Third-Party Model
    - Certification Authority example for Trusted Third-Party Model.
    - A third party sets the standards and manages the verification and due diligence process for all participants
    - Each participant and user are automatically considered trustworthy by all other participants.
    - Each participating organization subscribes to the standard and practices of a third party that manages the verification and due diligence processes for all participating companies.
    - Once a third party has verified the participating organization that organization is automatically considered trustworthy by all other participants.
    - Later, when users from one of the participants attempt to access a resource from another participant that organization only needs to confirm the user was certified by the trusted third party before allowing access.

- **Security Assertion Markup Language (SAML) EXAM IMP**
  - **Primary objective of SAML - Authentication**
  - XML Standard that allows the exchange of authentication and authorization data between security domains.
  - This information is communicated in the form of assertions over a secure HTTP connection, which conveys the identity of subjects and authorization decisions about the access level of the subjects.
  - It Provides the authentication pieces to the Federated Identity Management System.
  - Enables web-based authentication and authorization scenarios including SSO.
  - **Assertion is a claim, Statement, or declaration of the fact made by some SAML authority.**
  - There are three roles **(Very IMP for EXAM)**
    - **IDP (Identity Provider)**
      - It makes an assertion about another identity, based on information
      - This is the first entity. It makes an assertion about Another identity, based on the information it has. This information might have just been obtained, say by querying the user for a username/password pair
      - Entity Authenticating the user
    - **SP (Service Provider)**
      - This entity is the relying party that is being asked to provide its service or resource.
      - This entity is the relying party that is being asked to provide Its service or resource, based on the assurance provided by the IDP.
    - **Subject**
      - This entity is the subject of the assertion, usually a person, Who is in some sense being vouched for?
      - User who enters the authentication information
  - The four primary components of SAML are
    - **Assertions**
      - The assertion may also specify, in an authorization decision statement, conditions under which the principal is permitted to perform certain actions on a given resource.
      - SAML assertions themselves do not provide authentication of the user or principal.
    - **Protocols**
      - SAML protocols describe how information is to be exchanged between, or consumed by, SAML entities
    - **Bindings**
      - SAML bindings specify how to encapsulate the various SAML protocols in various types of messages. Since SAML 2.0, these bindings have described not only how to include queries in, for example, SOAP envelopes,

but also HTTP POST and GET exchanges (among others)

- **Profiles**
  - SAML bindings, protocols, and assertions can be pulled together to make a profile, a set of definitions, and instructions for a specified use case.

- **SAML Assertions are encoded in an XML schema and can carry up to three types of statements:**
  - **Authentication statements include information about the assertion issuer, the authenticated subscriber, validity period, and other authentication information.**
  - **Attribute statements contain specific additional characteristics related to the subscriber.**
  - **Authorization statements identify the resources the subscriber has permission to access.**



Security in SAML

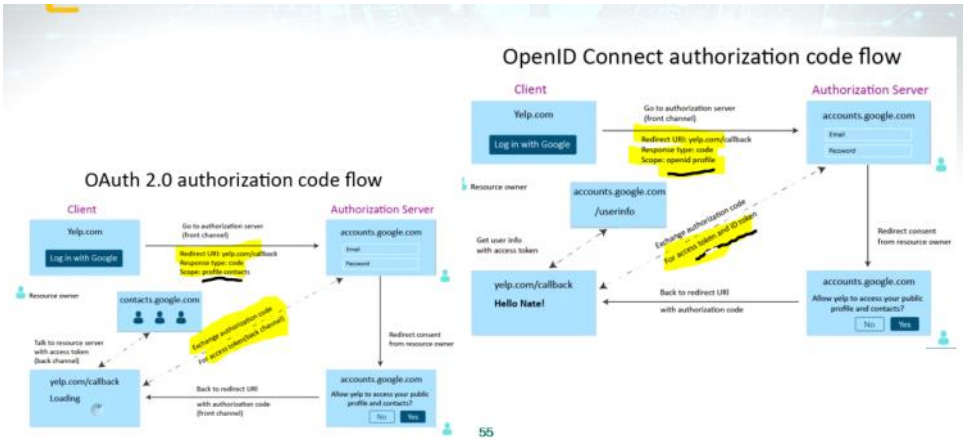
- Where message integrity and message confidentiality are required, then HTTP over SSL 3.0 or TLS 1.0 is recommended.
- SAML assertion can be encrypted using XML-Encryption
- When a relying party requests an assertion from an asserting party, bi-lateral authentication is required and the use of SSL 3.0 or TLS 1.0 using mutual authentication or authentication via digital signatures is recommended.
- When a response message containing an assertion is delivered to a relying party via a user's web browser (for example using the HTTP POST binding), then to ensure message integrity, it is mandated that the response message be digitally signed using XML Signature
- Assertions SHALL be cryptographically signed by the issuer (IdP). The RP SHALL validate the digital signature or MAC of each such assertion based on the issuer's key. This signature SHALL cover the entire assertion, including its identifier, issuer, audience, subject, and expiration.

- **Service Provisioning Markup Language (SPML)**
  - Format used to exchange information
  - Newer framework developed by OASIS which is based on XML and is specifically designed for exchanging user information for Federated Identity SSO purposes.
  - Based on Directory services markup language, which can display LDAP-based directory services information in an XML format.
  - Service Provisioning Markup Language (SPML) is a markup language, built on the Extensible Markup Language (XML) framework, that exchanges information about which users should get access to what resources and services.
- **Extensible Access Control Markup Language (XACML)**
  - Designed for Authorization and Describe the access control.
  - SAML share authentication (XML Token) and authorization (details) , The authorization details are XACML.
  - Standard developed by OASIS and is used to define access control policies within an XML format
  - It commonly implements policies as an attribute-based access control system but can use **role-based access control**.
  - It helps assure all members in a federation that they are granting the same level of access to different roles.
  - XACML and SAML are together used to create a federated IAM system.
  - **SAML is used to share authentication data between multiple services and applications.**
  - **XACML is used to let web services and applications interpret security policies and access permissions.**
    - Open ID
      - OpenID is an open standard for user authentication by third party
      - OpenID Connect enables scenarios where one login can be used across multiple applications, also known

as single sign-on

- **OpenID but uses a JavaScript Object Notation (JSON) Web Token (JWT), also called an ID token**
- The token contains a field signed with the shared secret, so the relying party is assured that the user is authenticated
- uses straightforward REST/JSON message flows with a design goal of making simple things simple and complicated things possible."
- The OpenID specification defines Three Roles
  - **End-User / Entity** That's looking to verify its identity
  - **Relying Party (RP)** Relying party is the entity looking to verify the identity of the end-user.
  - **Open ID Provider (OP)** OP is the entity that registers the Open ID URL and can verify the end user identity.

- OAuth
  - OAuth is different from OpenID & SAML is being exclusively for **Authorization purposes and not for Authentication purposes.**
  - The OAuth specification defines the following roles:
    - The **End User or The Entity** that owns the resources in Question
    - The **Resource Server** (OAuth Provider), which is the entity hosting the resource
    - The **Client (** OAuth **Consumer)** is the entity that is looking to consume the resource after getting authorization from the client.

- 

- **Summary**



The Differences Between Standards

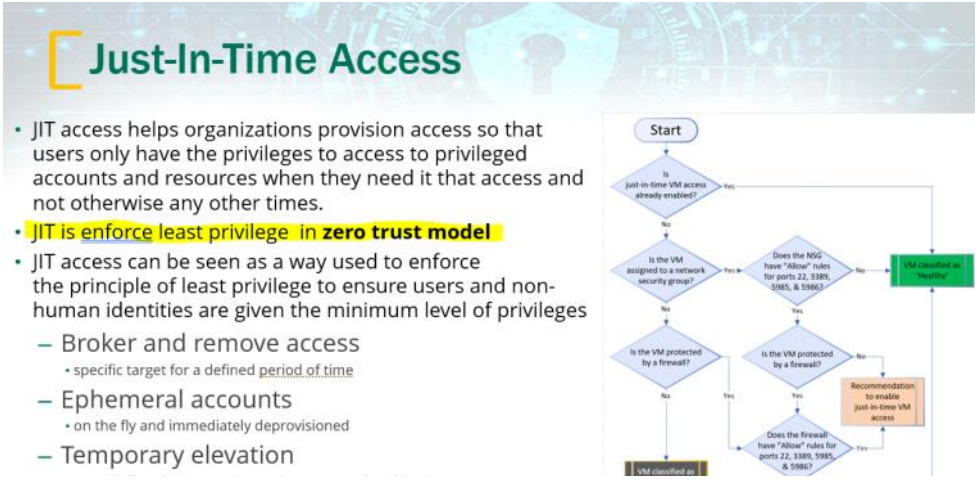
- The main differentiator between these three players is that
  - **OAuth 2.0 is a framework that controls authorization to a protected resource such as an application or a set** of files, while OpenID Connect and SAML are both industry standards for federated authentication. That means that OAuth 2.0 is used in fundamentally different situations than the other two standards (examples of which can be seen below), and can be used simultaneously with either OpenID Connect or SAML.
- Using either OpenID Connect or SAML independently, enterprises can achieve user authentication and deploy single sign-on. Though they both deal with logins, they have different strengths and weaknesses.
  - **OpenID Connect is built on the OAuth 2.0 protocol and uses an additional JSON Web Token (JWT),** called an ID token, to standardize areas that OAuth 2.0 leaves up to choice, such as scopes and endpoint discovery. It is specifically focused on user authentication and is widely used to enable user logins on consumer websites and

mobile apps.

- **SAML is independent of OAuth, relying on an exchange of messages to authenticate in XML SAML format, as opposed to JWT. It is more commonly used to help enterprise users sign in to multiple applications using a single login.**

- **Identity as a Service (IDaaS)**
  - Cloud-based IDM Solution - Identity as a service (IDAAS) in a cloud this is also called CASB - Cloud Access security broker.
  - IDaaS offers management of identity or information as a digital identity
  - This identity can be used during electronic transactions
  - Identity refers to a set of attributes associated with something to make it recognizable
  - Cloud-based service that broker identity and access management functions to target system/application on customers premises and/or in the cloud
  - A combination of administration and account provisioning, authentication, and authorization and reporting functions.
  - IDaaS provides Cloud-based services that broker IAM functions to target systems on the customer premise.
  - IDaaS is often paired with SaaS
  - Availability is the primary concern.
  - Use the following guidelines when implementing IDaaS:
    - Incorporate an IDaaS system with administration, access, and intelligence capabilities.
    - Consider offloading identity services to a cloud provider, especially if internal solutions prove too costly.
    - Keep in mind, however, that cloud services introduce a whole host of security issues.
    - Ensure that you understand the risks to privacy, auditing, and app integration that cloud identity and access management services provide.
    - Implement identity federation to streamline user interactions and identity management within the enterprise.
    - Implement identity federation to reduce the cost and the risk associated with multiple identity management systems.
    - Establish a cross-certification or third-party certification trust model in federated systems, depending on your organization's needs and capabilities.
    - Use a SAML-based federation framework like Shibboleth to securely manage individual identities.
    - Ensure that identity propagation has fine-grained control over whose identity gets propagated where so you conform to access control policies.
  - IDaaS should include functionality for the following:
    - **Identity governance and administration:** This includes the ability to create accounts and/or synchronize accounts.
    - **Access:** Allows for user authentication, and authorization perhaps providing SSO.
    - **Intelligence:** There is still a need for logging and I&A audits.
  - Cloud-based IDM/IAM Solution
    - Identity and Access Types
      - **On-Premise:** IAM mechanisms are locally installed on organizational components
      - **Off-Premise:** IAM mechanisms hosted by a vendor or service provider of the organizational control.
      - Why Off-Prem?
        - Off-premise is great for an organization that do not have the infrastructure or personnel to support on-premise IAM
        - Off-Prem Can be used for BC and DR scenarios
        - Support enterprise-wide SSO capability more effectively.
      - On-prem IAM components must be connected to Off-Prem IAM mechanisms to sync information securely on an encrypted channel.
      - **The primary concern between On-Prem and Off-prem is Synchronization and the path by which data is synchronized as it can be prone to sniffing.**
    - Features and Benefits
      - SSO authentication to internal and external services
      - Stronger Federation
      - Granular authorization control to a subset of data or functions
      - Administration
      - Integration with internal directory services
  - Cloud IAM Considerations
    - **Integration effort**

    - Newer applications have one or more interfaces available to facilitate automated account provisioning and single sign-on. Older applications usually lack these interfaces.
  - **Available resources**
    - Even for easily integrated applications, there is still some effort required to perform and maintain integrations over time.
  - **Efficiency tolerance**
    - If the organization is intolerant of inefficiencies, such as users having to log on to business applications many times each day, they may be more likely to pursue an IAM solution.
  - **Risk tolerance**
    - If an organization is averse to the risks associated with users possessing multiple sets of login credentials for critical business systems, it will be more apt to implement an IAM solution.
  - Some effort is required to perform and maintain integrations over time.
- Cloud Security
  - Cloud identity and access management Problems
    - **APIs** - Providers might offer some interfaces, but likely not all of them that are needed.
    - **Authorization mapping** - How users are granted privileges may need to change as identity is managed by the cloud provider.
    - **Audit:** Requesting logs from providers may be difficult, as the provider must be careful not to disclose logged data from other clients that share virtual machine tenancy.
    - **Privacy:** Sensitive user information is being sent over the Internet and stored on servers that you don't personally maintain. This can be a huge risk to the organization.
    - **Latency:** Configurations may take time to push out to the cloud. A delay in user rights changing may incur risk.
    - **App identity:** Apps won't necessarily check a client's identity, which can be a problem if you want to make sure your cloud-based users' identities aren't using unauthorized apps.
    - **Mobile:** Cloud providers often have mobile services, which adds another system and attack surface you need to defend.



Comparing SAML, OAuth, OpenID, and OIDC

It's easy to mix up the differences between SAML, OAuth, OpenID, and OIDC. This section summarizes key points of each one and points out some of the differences.
The following bullets outline the key points about SAML:

- SAML 2.0 is an open XML-based standard.
- OASIS adopted it as a standard in 2005.
- It utilizes three entities: a principal (such as a user), a service provider (such as a website), and an identity provider (a third party that holds the authentication and authorization information).
- It can provide authentication, authorization, and attribute information on the principal.

The following bullets outline the key points about OAuth:

- It can provide authentication, authorization, and attribute information on the principal.

The following bullets outline the key points about OAuth:

- It's an authorization framework, not an authentication protocol.
- RFC 6749 describes OAuth 2.0.
- It exchanges information using APIs.
- An app obtains an access token from an identity provider.
- Later, the app includes the access token for authorization.

The following bullets outline the key points about OpenID:

- OpenID is an authentication standard.
- It is maintained by the OpenID Foundation.
- An OpenID provider provides decentralized authentication.
- Users enter their Open ID identifier (such as `bobsmith2021.myopenid.com`) on a site and the OpenID provider verifies the identifier.

The following bullets outline the key points about OIDC:

- OIDC is an authentication layer using OAuth 2.0.
- It builds on the OpenID authentication standard.
- It provides both authentication and authorization.
- It builds on OpenID but uses a JSON Web Token.

Physical Access Control Systems

- When designing a PACS, it is critical to establish requirements for protection, as making changes to physical infrastructure is more difficult than changes like software upgrades. The first requirement that must be identified is who exactly needs access to a specified facility
- Elements might include one or more of the following:
  - User identification: People, vehicles, and other resources entering or leaving a secured area should be identified. This may be accomplished via a badge, sticker, radio frequency ID (RFID) tag, barcode, etc., as appropriate
  - Device identification: Nonhuman users may be tracked throughout the facility or at ingress and egress points using a variety of methods including identification stickers and RFID tags
  - Locks and keys: Although often implemented on gates or doors, locks can also be used to control physical access to individual assets such as hard-copy data in a filing cabinet, a sensitive laptop stored in a safe, or a locked server rack housing sensitive systems
  - Intrusion detection sensors: These are a detective control and can be useful to identify if improper access has been gained
  - Turnstile or mantrap: Turnstiles and mantraps are both designed to explicitly limit the rate of access to a facility. Turnstiles typically allow only one person through at a time, while a mantrap requires a user to enter a secure vestibule space by presenting one set of credentials and then requires a different set of credentials to move from the vestibule into the main space. These can be useful to guard against piggybacking, where one user attempts to gain access without presenting credentials by closely following an authorized user.
  - Guards: Guard staff are one of the most useful, flexible, and also most expensive forms of physical access control
- Emergency considerations must also be taken into account when designing a PACS, since human life, health, and safety are always a primary concern.

- MDM and MFA can be combined to provide powerful compensating control for challenges arising from increased remote work, cloud-based systems, and BYOD

